Capstone Assessment: Prioritized Risk Analysis for "ConnectSphere"

Cybersecurity Governance Report

Module: Cybersecurity Fundamentals for Modern Tech Roles
Role: Independent Cybersecurity Governance Consultant
Submitted by: MUPANDA LUBUTO JOSEPHUS (mupanda.lubuto@amalitech.com)
Scope: ConnectSphere architecture review, **Set 1** (Professional Event Networking MVP) and **Set 2** (Professional Connection Platform V1)
Frameworks applied: CIA Triad, Principle of Least Privilege (PoLP), Defense in Depth, Secure SDLC (SSDLC), OWASP Top 10, GDPR, CCPA/CPRA

Contents

Part	Content
Part A: Set 1	Flaws observed, Deliverable 1 (Governance Review Card), Deliverable 2 (annotated and corrected architecture), Deliverable 3 (summary)
Part B: Set 2	Flaws observed, Deliverable 1 (Governance Review Card), Deliverable 2 (annotated and corrected architecture), Deliverable 3 (summary)
Submission checklist	Mapping of this report to the assignment requirements

Executive summary

ConnectSphere must pass an investor security due-diligence review in fourteen days. Across both architecture variants, the review found the same five root causes: unencrypted transport, an unauthenticated or default-credential admin plane, missing input validation (SQL injection), a public tier that reaches the data tier directly, and no logging or incident response. Each root cause is mapped to a core principle and to a regulatory duty, and each has a concrete, role-specific fix.

Priority	Fix	Set 1	Set 2	Principle
1 (Critical)	Close the public admin dashboard (VPN / allow-list, SSO, MFA, RBAC, no default credentials)	Yes	Yes	PoLP, Confidentiality
2 (Critical)	Enforce HTTPS / TLS 1.2+ with HSTS	Yes	Yes	Confidentiality
3 (Critical)	Remove the hard-coded API key from frontend code and rotate it	No	Yes	Confidentiality
4 (High)	Prepared statements, input validation and output encoding	Yes	Yes	Integrity, SSDLC
5 (High)	Rate limiting, WAF, redundancy and backups	Yes	Yes	Availability
6 (High)	Central audit logging, alerting and an incident response plan	Yes	Yes	Accountability

Part A: Set 1: ConnectSphere – Prioritized Risk Analysis (Set 1)

Role: Independent Cybersecurity Governance Consultant
Scope: ConnectSphere – Professional Event Networking MVP (user profiles, event registration, secure messaging)
Data in scope: PII (name, email, phone, company, title) and event registration data
Frameworks applied: CIA Triad, Principle of Least Privilege (PoLP), Defense in Depth, Secure SDLC (SSDLC), OWASP Top 10, GDPR, CCPA/CPRA

Flaws observed in the Set 1 diagram

#	Observation in the diagram	Principle violated	Reference
A	Browser / mobile app → Web Server over **HTTP (unencrypted)**	Confidentiality (data in transit)	OWASP A02, CWE-319, GDPR Art. 32
B	**Admin Dashboard Access: Public, No Auth** between the two databases	Confidentiality, PoLP, access control	OWASP A01/A07, CWE-306
C	Application Backend sends **SQL queries without prepared statements**	Integrity, input validation	OWASP A03, CWE-89
D	Public-facing EC2 web servers connect **directly to the databases**, bypassing API Gateway and backend	Defense in Depth, PoLP, segmentation	CWE-653
E	**Two separate "User Database" MySQL instances** with no defined source of truth	Integrity and Availability	GDPR Art. 5(1)(d), Art. 32(1)(b)(c)
F	**Phone Verification Service** and SMS Gateway feed the backend and DB directly, with no visible authentication, rate limiting or replay protection	Integrity, Availability (SMS abuse)	OWASP A07, CWE-770
G	No logging, monitoring or incident response component anywhere	Accountability, detection	OWASP A09, GDPR Art. 33
H	No visible session management (tokens, cookies, expiry)	Confidentiality, authentication	OWASP A07

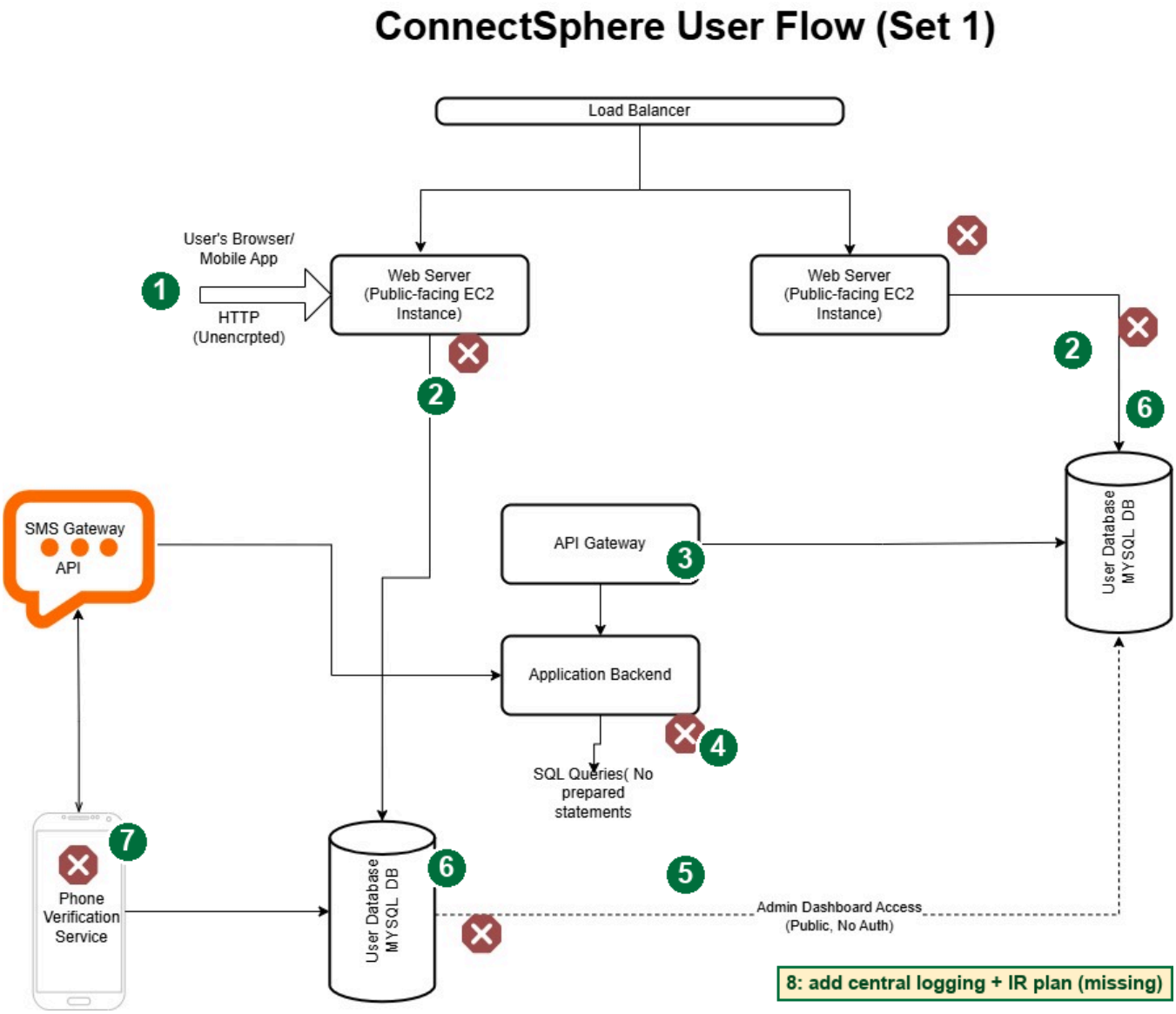
Deliverable 1 – Cybersecurity Governance Review Card

Section	Issue / Definition	Impact	Suggested Fix / Mitigation
1. Confidentiality Risk *(CIA – Confidentiality, PoLP)*	PII travels over **plain HTTP**, and the **admin dashboard is public with no authentication** and has access to the user databases. Anyone on the network path, or anyone on the internet, can read or export names, emails, phone numbers and registrations.	Mass PII disclosure and account takeover. GDPR Art. 32 and Art. 33 breach (72h notification), CCPA statutory damages, loss of investor trust. **Severity: Critical.**	Enforce **HTTPS (TLS 1.2+)** with HSTS and redirect all HTTP traffic. Terminate TLS on the load balancer with an ACM certificate and re-encrypt to the backend. Remove public exposure of the admin dashboard: reach it only through VPN / bastion + SSO with **MFA**, and apply **RBAC** (PoLP). Encrypt databases at rest (KMS).

Section	Issue / Definition	Impact	Suggested Fix / Mitigation
2. Integrity Risk *(CIA – Integrity, Input Validation, SSDLC)*	The backend builds **SQL queries without prepared statements** and there is no input validation. In addition, web servers write straight to the databases and two different User DBs exist, so there is no single authoritative record.	SQL injection lets an attacker alter, delete or exfiltrate data. Divergent copies of user records cause corrupted profiles and registrations. **Severity: High.**	Use **parameterized queries / ORM**, server-side allow-list validation and output encoding. Add schema validation at the API Gateway. Give the backend a **least-privilege DB account** (no DROP / GRANT). Consolidate to **one authoritative User DB**. Add SAST/DAST and code review gates in the CI/CD pipeline (SSDLC).
3. Availability Risk *(CIA – Availability, Defense in Depth)*	Public EC2 web servers have direct DB connections and there is **no rate limiting or WAF**. The phone-verification / SMS flow can be hammered (SMS pumping). Duplicate DBs have no stated HA, backup or failover design.	DDoS, injection-driven DB overload or a single DB failure makes registration and messaging unavailable. SMS abuse also creates uncontrolled costs. **Severity: Medium-High.**	Place **AWS WAF + Shield** and API Gateway **throttling** in front. Move web servers to private subnets and let only the backend reach the DB. Run the DB **Multi-AZ with automated backups and tested restores** (defined RTO / RPO). Add per-number and per-IP OTP limits with expiry and CAPTCHA.
4. Monitoring / Reporting Recommendation	**Metric:** *Unauthorized Access Attempts per Hour*, the count of HTTP 401/403 responses and failed authentications on admin and API endpoints, broken down by endpoint and by (pseudonymized) source.	**Visualization: Heatmap** (hour of day × endpoint), with an alert threshold overlay.	**Why it matters:** it reveals brute-force, scanning and privilege-escalation attempts early, so the team can contain an incident inside the 72-hour GDPR notification window.

Deliverable 2 – Corrected Architecture Diagram

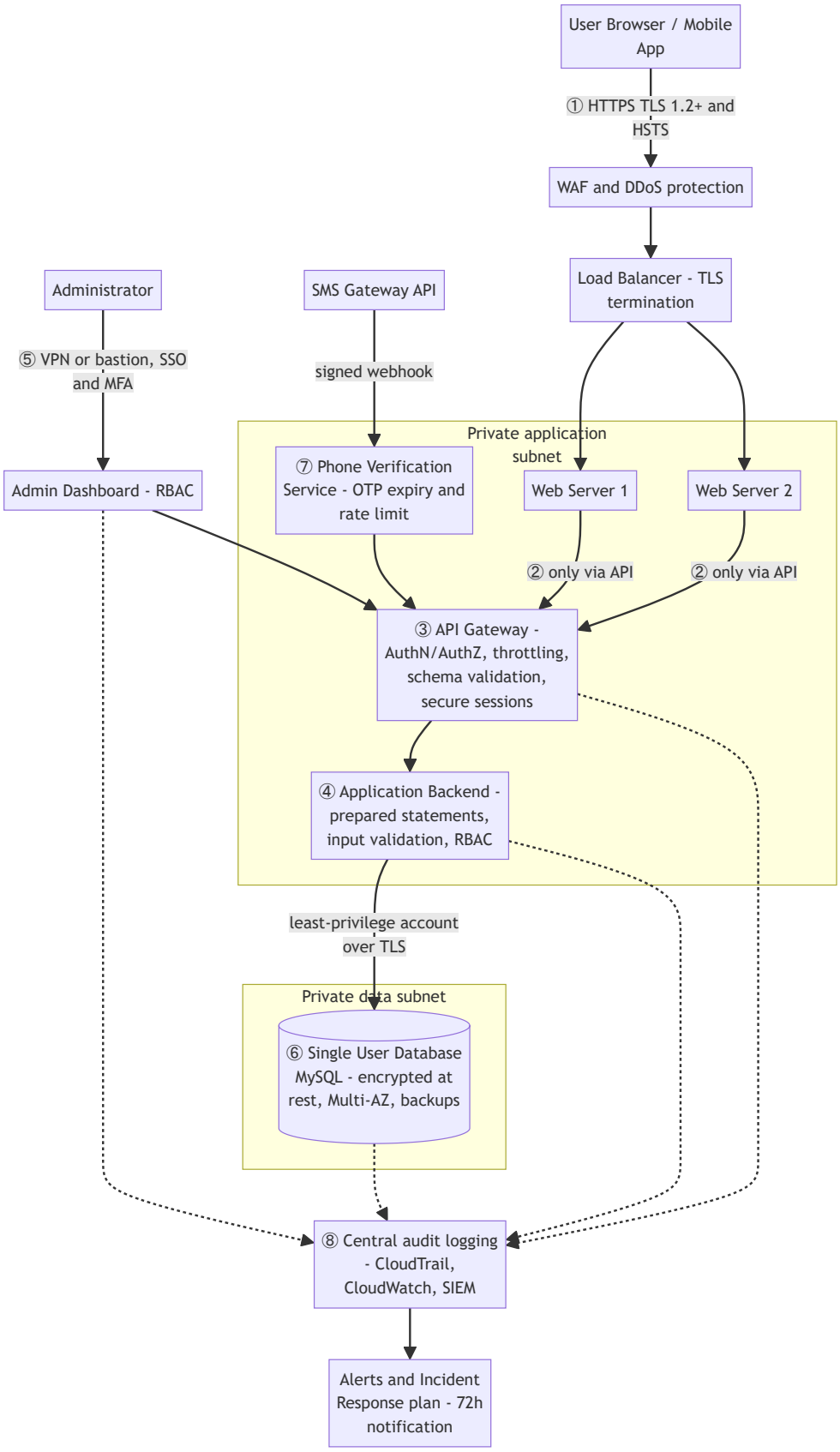
Annotated original (flaw → correction)



Marker	Location on the original diagram	Correction made	Why
①	Browser → Web Server, "HTTP (Unencrypted)"	Replace with **HTTPS / TLS 1.2+**, HSTS, HTTP→HTTPS redirect, TLS to the backend	Protects PII and ensures data-in-transit confidentiality.
②	Both Web Servers → User DB (direct lines, red ✕)	**Remove direct DB access.** Web servers move to a private subnet and call only the API Gateway	Defense in Depth and PoLP: the public tier must never touch the data tier.
③	API Gateway	Add **authentication (OAuth2 / JWT), authorization, throttling and request-schema validation**. Sessions use `Secure; HttpOnly; SameSite` cookies or short-lived tokens with rotation	Closes weak API access control and adds secure session management.
④	Application Backend, "SQL Queries (No prepared statements)"	**Prepared statements / ORM** + server-side validation + least-privilege DB account	Stops SQL injection and protects data integrity.

Marker	Location on the original diagram	Correction made	Why
⑤	"Admin Dashboard Access (Public, No Auth)"	Remove the public path. Access only via **VPN / bastion + SSO + MFA + RBAC**, with every admin action logged	PoLP and prevention of privilege escalation.
⑥	Two "User Database MYSQL DB"	**Merge into one authoritative DB**: encrypted at rest, Multi-AZ, backups, private subnet	Eliminates data divergence and improves availability and integrity.
⑦	Phone Verification Service / SMS Gateway	Verification goes **through the API Gateway only** (signed webhooks, OTP expiry, retry and rate limits) and never writes to the DB directly	Prevents forged verification and SMS abuse.
⑧	*(missing)*	Add **centralized audit logging (CloudTrail / CloudWatch → SIEM)**, alerts and a documented **Incident Response plan**	Detection, accountability and breach notification (GDPR Art. 33).

Corrected architecture



Deliverable 3 – Summary of Review Process

I began by reading the project brief and tracing every data flow in the Set 1 diagram, tagging each red marker with the principle it breaks. Under the **CIA Triad**, unencrypted HTTP and the public admin dashboard threatened confidentiality, missing prepared statements and duplicate databases threatened integrity, and direct web-to-database links with no rate limiting threatened availability. I applied the **Principle of Least Privilege** by removing the public admin path, forcing MFA and RBAC, and giving each component only the database rights it needs. **Secure SDLC** practice appears as parameterized queries, input validation, and SAST/DAST checks in the pipeline, so these flaws are caught before release.

These findings directly improve compliance. TLS, encryption at rest and access control satisfy GDPR Art. 32 (security of processing) and support Art. 25 (data protection by design). Centralized logging and an incident response plan make the 72-hour notification duty of Art. 33 achievable. A single authoritative user database supports data accuracy under Art. 5(1)(d) and makes access and deletion requests under GDPR and CCPA easier to honour. For the investors' due diligence, each fix maps to a recognized control, which makes the remediation auditable.

The recommended metric, *Unauthorized Access Attempts per Hour*, supports ethical and transparent governance because it measures protection of users rather than surveillance of them. It can be reported in aggregate, with pseudonymized sources, to leadership and investors. It gives an honest, evidence-based view of risk, and it shows the organization is accountable for protecting the personal data it holds.

Part B: Set 2: ConnectSphere – Prioritized Risk Analysis (Set 2)

Role: Independent Cybersecurity Governance Consultant
Scope: ConnectSphere – Professional Connection Platform V1 (profiles, virtual workshop RSVP, moderated forums, planned "contact request" feature)
Data in scope: Profile data (name, employer, title, skills, LinkedIn URL), event attendance records, forum post content
Frameworks applied: CIA Triad, Principle of Least Privilege (PoLP), Defense in Depth, Secure SDLC (SSDLC), OWASP Top 10, GDPR, CCPA/CPRA

Flaws observed in the Set 2 diagram

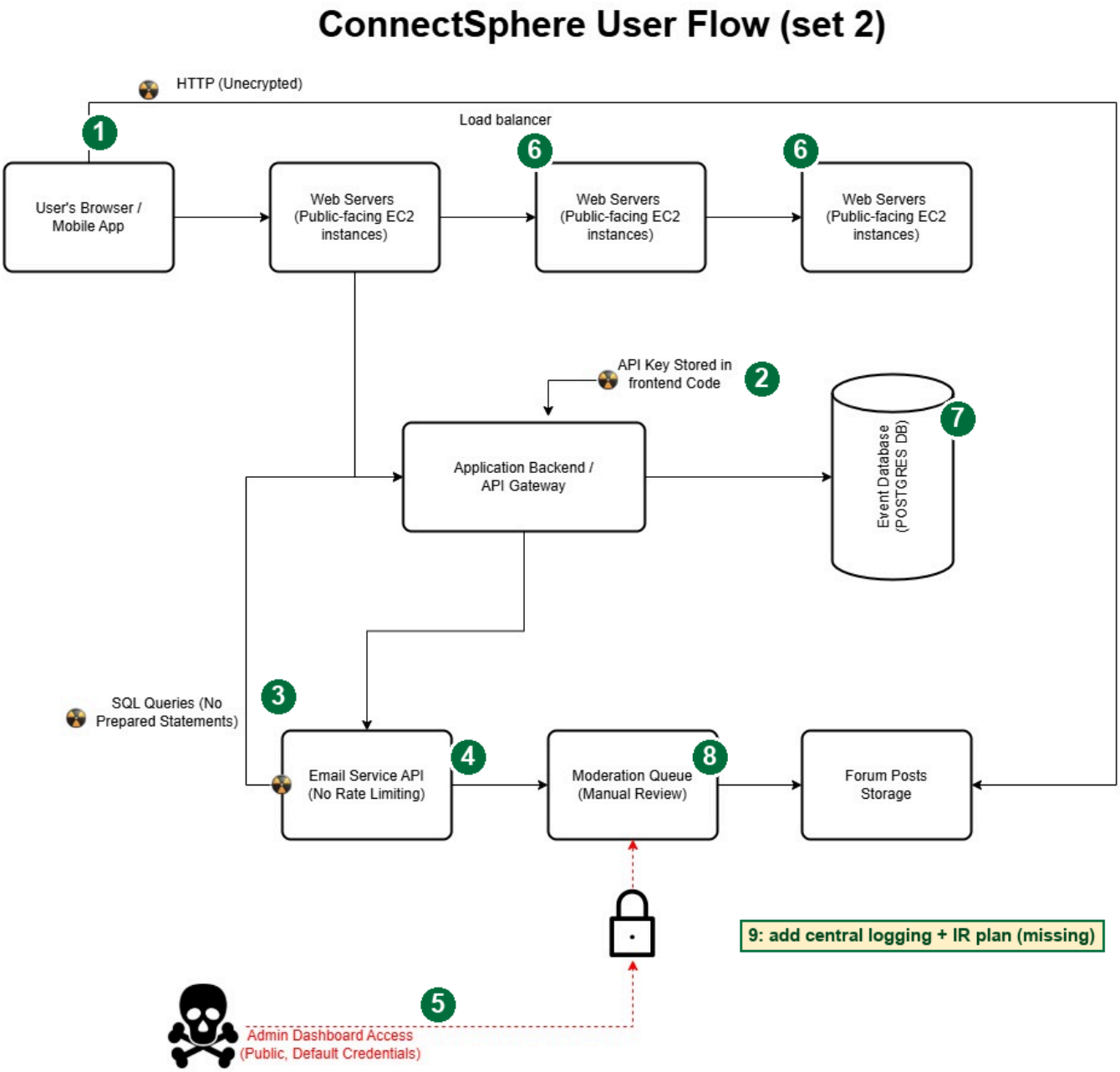
#	Observation in the diagram	Principle violated	Reference
A	Browser → Web Servers / Forum Posts Storage over **HTTP (unencrypted)**	Confidentiality (data in transit)	OWASP A02, CWE-319, GDPR Art. 32
B	**API key stored in frontend code** feeding the Application Backend	Confidentiality, secrets management	OWASP A05/A07, CWE-798
C	**SQL queries without prepared statements**	Integrity, input validation	OWASP A03, CWE-89
D	**Email Service API has no rate limiting**	Availability, abuse prevention	OWASP API4, CWE-770
E	**Admin Dashboard Access: Public, Default Credentials**, reaching the Moderation Queue	Confidentiality, Integrity, PoLP	OWASP A07, CWE-1392
F	Web servers are drawn in a **chain** (server → server → server) instead of in parallel behind the load balancer, and one web server reaches Forum Posts Storage and the backend directly	Availability (single points of failure), Defense in Depth	CWE-653
G	Forum content is stored and published with no stated sanitization, and the **manual-only moderation queue** is a bottleneck	Integrity (stored XSS), Availability	OWASP A03
H	One PostgreSQL event DB with no stated replication, backup or encryption	Availability, Confidentiality	GDPR Art. 32(1)(b)(c)
I	No logging, monitoring or incident response; no session management	Accountability, detection	OWASP A09, GDPR Art. 33

Deliverable 1 – Cybersecurity Governance Review Card

Section	Issue / Definition	Impact	Suggested Fix / Mitigation
1. Confidentiality Risk *(CIA – Confidentiality, PoLP)*	Profile data and sessions travel over **plain HTTP**, an **API key is hard-coded in frontend code** (readable by any visitor), and the **admin dashboard is public with default credentials**.	Interception of profile data, theft of the API key to call backend and email services as ConnectSphere, and full admin takeover of moderation. GDPR Art. 32 / 33 breach and CCPA exposure. **Severity: Critical.**	Enforce **HTTPS / TLS 1.2+** with HSTS. Move all secrets to the backend in a **secrets manager** (AWS Secrets Manager), **rotate the exposed key now**, and give the frontend only short-lived user tokens. Remove the public admin path: VPN / allow-list + SSO + **MFA**, no default credentials, **RBAC** (PoLP).
2. Integrity Risk *(CIA – Integrity, Input Validation, SSDLC)*	**SQL built without prepared statements** and no validation or output encoding of forum content. The compromised or unauthenticated admin path can also approve, edit or delete moderated posts.	SQL injection corrupts or leaks event and attendance records. Stored XSS in forum posts hijacks other users' sessions. The USP of a "curated and secure environment" is destroyed. **Severity: High.**	**Parameterized queries / ORM**, allow-list validation, **output encoding and a Content-Security-Policy** for forum content. Least-privilege DB accounts. Make moderation actions **audit-logged and immutable**. SAST/DAST and peer review in the CI/CD pipeline (SSDLC).
3. Availability Risk *(CIA – Availability, Defense in Depth)*	The **Email Service API has no rate limiting** (spam, email-bombing, cost abuse, and a likely vector for the planned "contact request" feature). Web servers are chained, which creates single points of failure, and the single event DB has no stated HA or backup.	Email provider blocks or suspends the sender, events become unreachable during a flood, and the business goal of "consistent availability for events" is missed. **Severity: High.**	**Rate limiting and quotas** per user / IP, CAPTCHA, queue-based sending, SPF / DKIM / DMARC. Put web servers **in parallel behind the load balancer** across AZs with auto-scaling and WAF / Shield. Run PostgreSQL **Multi-AZ with automated backups and tested restores** (defined RTO / RPO).
4. Monitoring / Reporting Recommendation	**Metric:** *Email API Request Rate vs. Threshold*, requests per minute per account and per IP to the Email Service API, plus the count of throttled (HTTP 429) requests.	**Visualization: Line chart** (time series with a threshold line and a 429 overlay).	**Why it matters:** it exposes spam, abuse and credential-stuffing patterns before they exhaust the email service and take events offline.

Deliverable 2 – Corrected Architecture Diagram

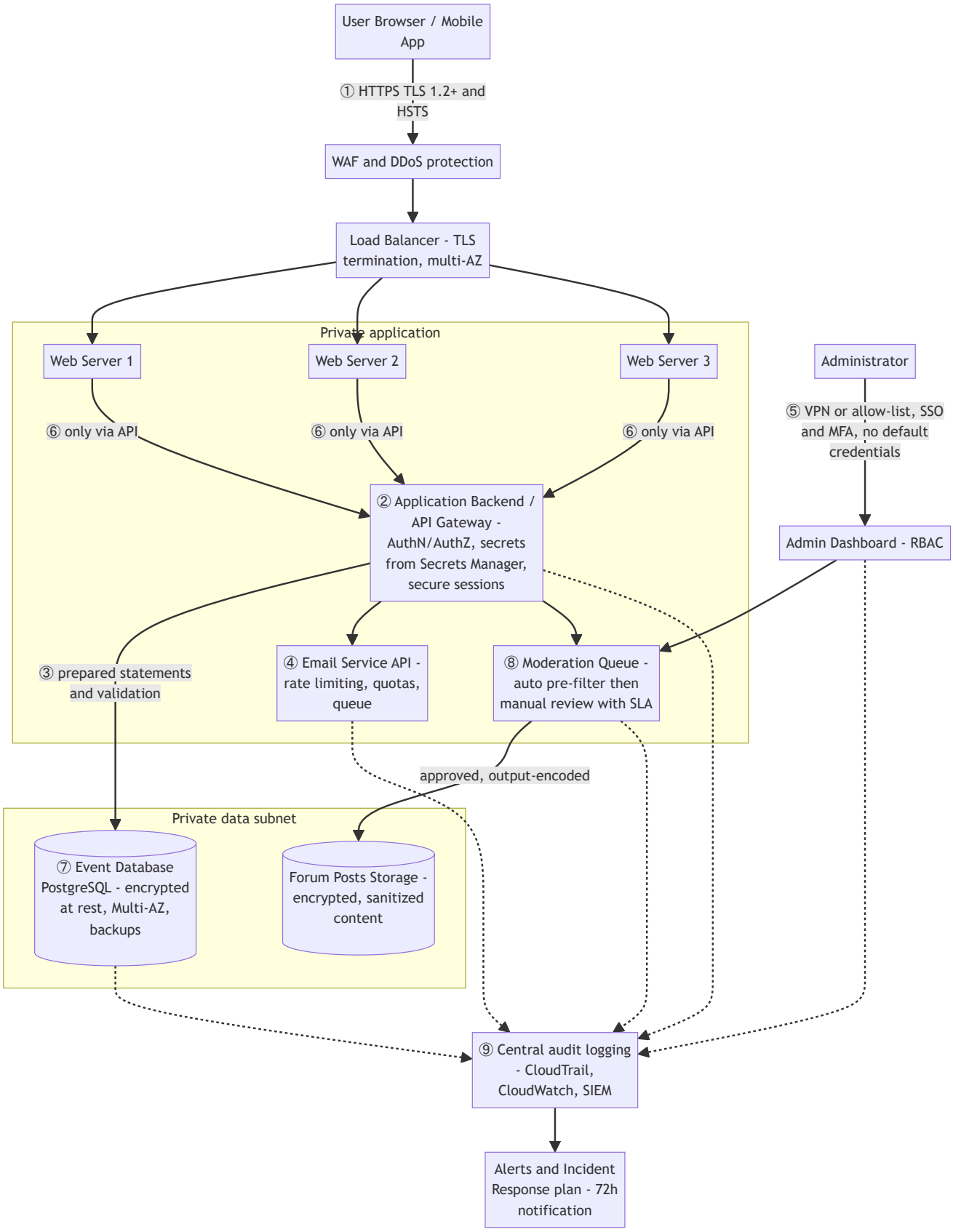
Annotated original (flaw → correction)



Marker	Location on the original diagram	Correction made	Why
①	"HTTP (Unencrypted)" path from the User's Browser	**HTTPS / TLS 1.2+** end to end, HSTS, HTTP→HTTPS redirect	Protects profile data and ensures data-in-transit confidentiality.
②	"API Key Stored in frontend Code"	Move the key to the **backend and a secrets manager**, rotate it, and use short-lived tokens with `Secure; HttpOnly; SameSite` cookies for sessions	Removes a hard-coded secret and adds secure session management.
③	"SQL Queries (No Prepared Statements)"	**Prepared statements / ORM**, server-side validation, output encoding for forum content	Stops SQL injection and stored XSS, and protects integrity.

Marker	Location on the original diagram	Correction made	Why
④	"Email Service API (No Rate Limiting)"	**Rate limiting, quotas, CAPTCHA, queue**, SPF / DKIM / DMARC	Prevents spam and abuse and keeps the service available.
⑤	"Admin Dashboard Access (Public, Default Credentials)"	Remove the public path. **VPN / allow-list + SSO + MFA + RBAC**, no default credentials, forced rotation	PoLP and prevention of unauthorized moderation.
⑥	Chained Web Servers, and direct paths to the backend and Forum Posts Storage	Web servers sit **in parallel behind the load balancer** and talk **only to the API Gateway**. Storage and DB live in private subnets	Removes single points of failure and enforces Defense in Depth.
⑦	Event DB and Forum Posts Storage	**Multi-AZ PostgreSQL**, encryption at rest (KMS), backups, restore tests	Availability and confidentiality of stored data.
⑧	Moderation Queue (Manual Review)	**Automated pre-filter + manual queue with an SLA**, least-privilege moderator role	Keeps the "spam-free" USP without creating a bottleneck.
⑨	*(missing)*	**Central audit logging (CloudTrail / CloudWatch → SIEM)**, alerts and an **Incident Response plan**	Detection, accountability and breach notification (GDPR Art. 33).

Corrected architecture



Deliverable 3 – Summary of Review Process

I reviewed the Set 2 brief first, noting that its promise of a "curated and secure environment" with consistent availability sets the bar, then traced each flow in the diagram and linked every red marker to a principle. Under the **CIA Triad**, HTTP, a hard-coded API key and a public admin panel with default credentials threaten confidentiality. Missing prepared statements and unsanitized forum content threaten integrity. An unthrottled email API and chained web servers threaten availability. I applied the **Principle of Least Privilege** through MFA, RBAC, a restricted moderator role and least-privilege database accounts, and **Secure SDLC** through parameterized queries, secrets management and automated security testing before release.

These fixes strengthen compliance. TLS, encryption at rest and access control align with GDPR Art. 32, while privacy by design for the planned contact-request feature aligns with Art. 25. Audit logging and an incident response plan make Art. 33 breach notification realistic, and CCPA's "reasonable security" expectation is met by documented controls. This gives the investors' auditors verifiable evidence instead of promises.

The recommended metric, *Email API Request Rate vs. Threshold*, supports ethical and transparent governance because it monitors system behaviour and abuse, not the content of people's messages. It can be shared in aggregate with leadership and investors, it protects users from spam and harassment, and it shows measurable accountability for the platform's availability and trustworthiness.

Submission Checklist

Requirement from the assignment	Where it is addressed
Deliverable 1: Governance Review Card with 3 findings (Confidentiality, Integrity, Availability) and 1 monitoring recommendation	Part A and Part B, "Deliverable 1"
Each finding references a core principle (CIA Triad, PoLP, input validation, SSDLC)	The "Section" column of each Review Card names the principle
Monitoring recommendation gives metric name and definition, visualization type and a one-sentence reason	Row 4 of each Review Card
Deliverable 2: annotated architecture diagram with at least 3 explained corrections	Part A: 8 corrections. Part B: 9 corrections. Each has a numbered marker on the original diagram, a "what changed" and a "why"
Key flaws covered: encryption, API access control, input validation, session management, audit logging and incident response	Corrections 1, 3 to 5 and 8 (Set 1). Corrections 1, 2, 3, 5 and 9 (Set 2)
Deliverable 3: summary of 200 to 300 words covering CIA / PoLP / SSDLC, compliance and data protection, and the ethics of the monitoring metric	Part A and Part B, "Deliverable 3" (each summary is within 200 to 300 words)